تقرير المرحلة 2 — CD-006 (البنود 7–10)

الحقل	القيمة
المشروع	نظام تقييم الأداء الوظيفي (Employee Evaluation)
الوحدة	C2/C3 — المستخدمون والأدوار والصلاحيات (RBAC)
الكيان المكلَّف	كبير المطورين
المرحلة	**المرحلة 2 — البنود 7–10 (اكتمال كامل)**
التاريخ	2026-09-28
الحالة	**مكتملة (4/4) — جاهزة للاعتماد**
قاعدة الإنتاج	`employee_evaluation_mvc` على XAMPP (`localhost`)
سجل التنفيذ الكامل	`CD-006_IMPLEMENTATION.md`
Guardrail	**متوقّف إلزاميًا** قبل أي عمل على البند 11 فما بعده

---

1. ملخص تنفيذي

نُفِّذت **بنود المرحلة الثانية الأربعة** (7، 8، 9، 10) من خطة CD-006 بثلاث ركائز ثابتة: **شيفرة المصدر في جذر مستودع التطبيق**، و**بلا أي ترحيل قاعدة بيانات** في هذه المرحلة، و**إثبات حي** لكل بند (اختبار وحدة للبندين 9، وHTTP حي للبنود 7 و8 و10). كل بند مُغلق بخط إغلاق إلزامي في `CD-006_IMPLEMENTATION.md`، والتغييرات مسجَّلة في `CHANGELOG.md` للطرفين.

النتيجة: حارس RBAC مُفعَّل فعليًا لا صوريًا (البند 7) · سجل التدقيق صار يحفظ القيم قبل/بعد (البند 8) · استبدال الأدوار صار ذرّيًا فلا يفقد المستخدم دوره (البند 9) · إنشاء المستخدم صار يتحقق مرجعيًا من الدور والموظف مع أثر تدقيق (البند 10). **قاعدة البيانات في خط أساس نظيف**، والسجلات التاريخية في `audit_logs` سليمة عددًا ومحتوى.

قرار التشغّل: بعد هذا التقرير **لا يُنفَّذ** البند 11 ولا b-12 ولا أي بند لاحق حتى اعتماد المستشار. والبنود المتبقية مذكورة في §7.

---

2. نطاق المرحلة الثانية

البند	العنوان	الحالة	طبيعة الإثبات
7	تفعيل صلاحيات `users.*` في حارس `UserController`	✅ مكتمل	Live HTTP (200/403)
8	تدقيق القيم القديمة/الجديدة في `audit_logs`	✅ مكتمل	Live HTTP 6 عمليات + مطابقة old/new
9	ذرّية استبدال الأدوار في `User::updateRole`	✅ مكتمل	اختبار وحدة 3/3 + إثبات كشف العطل
10	بوابات التحقق المرجعي قبل إنشاء المستخدم	✅ مكتمل	Live HTTP 4 سيناريوهات

Step A (توثيق): 12 إصلاحًا توثيقيًا على مستندات الوحدة بعد اعتماد المستشار البند 7 — commits `9a69680` (تسليم) و`f4ae1f9` (تطبيق/CHANGELOG).

---

3. التنفيذ التفصيلي

بند 7 — تفعيل صلاحيات `users.*` في الحارس

- **المشكلة:** الحارس كان `Auth::is('Admin')` ⟦؟⟧ فحص بالاسم لا بالصلاحية، و`header.php` كان

يخفي قائمة المستخدمين خلف كتلة الإعدادات. ـ **التنفيذ:** `__construct` صار `Auth::can('users.view')`، ولكل عملية حارسها: `create+store` ⇒ `users.create`، `edit+update+updateRole+toggleStatus+resetPassword` ⇒ `users.edit`، `destroy` ⇒ `users.delete`. قائمة `users/roles` في `header.php` نُقلت خارج كتلة الإعدادات ومقيَّدة بـ`Auth::isAdmin()` `userHasPermission('users.view')`. ـ **الإثبات:** HTTP 200/403 حيًّا + `php -l` نظيف. `/app/` لم يُمسّ في Commits** - .Step A:** تطبيق `f44d525` · توثيق Step A · `ff66d2f` · `459f7a9` · `404d5b3` · `f4ae1f9` / `9a69680`.

بند 8 — تدقيق القيم القديمة/الجديدة

- **النطاق:** `UserController::updateRole` و`toggleStatus`، و`RoleController::updatePermission` و

`updateRole` (وصف الدور). **`Audit.php` بلا تعديل.** ـ **التنفيذ:** قبل كل تعديل يُقرأ الصف القديم، وبعد النجاح يُسجَّل `old` و`new`. ـ **الإثبات:** 6 عمليات حيّة كلّها 7/7 · 200 أشكال old/new مطابقة · `utf8=valid` · **السجلات التاريخية 246 = 726=>id** صفًا سليمة** (لم تُمسّ) وأُبقيت صفوف الإثبات 727–764. - **Commits:** تسليم `93294f0` · تطبيق `bcb12a7` · إغلاق `1e9de66`.

بند 9 — ذرّية استبدال الأدوار

- **المشكلة:** `DELETE` ثم `INSERT` بلا معاملة؛ فشل `INSERT` بعد نجاح `DELETE` (مثل `role_id` غير موجود) يترك المستخدم **بلا دور نهائيًا**. ـ **اكتشاف مهّد:** القيد `user_roles_ibfk_2 FOREIGN KEY (role_id) REFERENCES roles(id)` يجعل `role_id=999` **يرمي `PDOException` فعلًا**، وكان ذلك يسمح باختبار rollback حاسم بلا تحقق مسبق. ـ **التنفيذ:** `beginTransaction()` على `Database::getInstance()->getPdo()` (نفس اتصال الـsingleton ⇒ المعاملة تغطي الاستعلامين)، ثم `DELETE+INSERT+commit`؛ وفي `catch: rollBack()` (بتحقّق `inTransaction()`) فيُرجع الصف المحذوف، ثم `SELECT id FROM roles` لتمييز السبب: غير موجود ⟦؟⟧ `return false`، وخطأ آخر ⟦؟⟧ `throw` كما كان. ـ **الإثبات:** `tests/cases/Models/UserTest.php` جديد · **3/3 نجح**. **شغل حاسم:** بعد `git stash` للإصلاح فشل الاختبار بـ`SQLSTATE[23000] … 1452` — أي أن الكود القديم يرمي استثناءً غير ملتقط **بعد** تنفيذ DELETE (وهو الخطر الموصوف). لا انحدار (نتيجة المجموعة الكاملة = خط الأساس). ـ **قرار المستشار:** **بلا Audit عند الفشل** (نص البند لا يطلبه و`Audit.php` خارج نطاقه) ⟦؟⟧ فجوة موثّقة في §7 للمراجعة في Commits** - .+CD-007:** تسليم `a3dbc07` · تطبيق `1a7f650` · إغلاق `c4096fc`.

بند 10 — بوابات التحقق المرجعي قبل الإنشاء

- **التنفيذ:** ثلاث بوابات في `UserController::store()` **قبل** `createUser` (إضافة فقط 0–/42+):

دور غير موجود ✅ USER_CREATE_BLOCKED_INVALID_ROLE + «الدور المحدد غير موجود.» · موظف غير موجود ✅ USER_CREATE_BLOCKED_INVALID_EMPLOYEE + «الموظف المحدد غير موجود.» · موظف مرتبط بحساب آخر ✅ USER_CREATE_BLOCKED_EMPLOYEE_TAKEN + «هذا الموظف مرتبط بحساب مستخدم آخر.» (مع linked_user_id). كل بوابة: فحص ⇒ Audit (entity_id=null، user_id=المنفِّذ) + Flash + إعادة توجيه + exit. role_id الفارغ/0 ✅ رسالة الدور غير الموجود. ـ **الإثبات (4 سيناريوهات Live، كلّها 200):** ثلاث حالات مرفوضة **بلا** إنشاء أي مستخدم مع الرسالة المحدّدة + صف التدقيق الخاص، وحالة سليمة أنشأت المستخدم بدوره وموظفه. صفوف التدقيق 811–815; حُذف حسابا الاختبار ✅ 0 = %.a2i10. ـ **توصيف دقيق للأثر (مُقاس):** القيود في قاعدة البيانات (user_roles_ibfk_2 و UNIQUE users.employee_id) كانت **منع الصفوف السيئة أصلًا** — تشغيل موازٍ على الكود قبل البوابات أعاد HTTP 200 و**0 صف تدقيق** و**لا مستخدم** مع رسالة **مضلِّلة** «قد يكون اسم المستخدم أو البريد الإلكتروني مستخدماً بالفعل.». فقيمة البند 10 هي (أ) رسالة صحيحة ومحدّدة و(ب) أثر تدقيق يتيح تتبّع المحاولة المرفوضة — **لا** «منع تلف» (بخلاف البند 9 الذي كانت فيه خسائر حقيقية). - **Commits:** تسليم dac9e06 · تطبيق 792d6c9 · إغلاق bb583f2.

---

4. سجل Git (مستودعان منفصلان)

البند	commit التطبيق	commit التسليم	commit الإغلاق
7	f44d525	ff66d2f / 459f7a9 / 404d5b3	—
A Step	f4ae1f9	9a69680	—
8	bcb12a7	93294f0	1e9de66
9	1a7f650	a3dbc07	c4096fc
10	792d6c9	dac9e06	bb583f2

نمط التسلسل المعتمد: **commit التسليم ← commit التطبيق ← commit إغلاق يثبّت الـhashes**.

---

5. حالة بيئة الاختبار وقاعدة البيانات

حالة نهائية مُتحقَّق منها بعد البندين 9 و10:

المقياس	القيمة	ملاحظة
users	30	4 مستخدمين حقيقيين + 26 حساب اختبار قديم (يُنظَّف في البند 11)
roles	4	Admin / HR / Manager / Staff
user_roles	20	بلا يتام
permissions	38	روابط Admin = 35
employees	27	بلا ربط خاطئ
audit_logs	289	= 284 (خط أساس) + 5 إثبات البند 10

السجلات التاريخية id<=726 = 246 **سليمة عددًا ومحتوى** (لم تُمسّ في أي بند)

- php -l نظيف على كل ملف عُدِّل. UserTest 3/3 بعد كل تغيير.
- **بلا انحدار:** نتيجة tests/runner.php الكاملة مطابقة لخط الأساس على الكود قبل التغيير.

• **XAMPP** (httpd + mysqld) **مُبقًى يعملًا** بطلب المستخدم حتى بعد هذا التقرير.

---

6. فحوصات إضافية ومكتشفات (خارج نطاق البنود)

#	الاكتشاف	الأثر	التوصية
1	**AuthTest يُنشئ ~14 حساب `cd004.*@test.local` في كل تشغيل ولا ينظّفها** (26 متراكمًا سابقًا؛ 52 من تشغيلاتي حُذفت فورًا لاستعادة خط الأساس)	تضخيم قاعدة الإنتاج مع كل تشغيل	**أولوية البند 11** (قرار المستشار Q3) — أو عزل الاختبار بقاعدة بيانات منفصلة
2	**RouterTest يُسقط مشغّل الاختبارات** بخطأ `View 'errors/404' does not exist.`	يمنع بقية الملفات (ومنها UserTest) من التنفيذ في التشغيل الكامل	إصلاح في بند لاحق؛ حتى ذلك كان إثبات البند 9 عبر `runner.php UserTest` مباشرة
3	**3 اختبارات وحدة فاشلة قبل التغيير** (خط أساس): `AuthTest::testAdminUserControllerGuardStopsNonAdmin` · `DatabaseTest::testRowCount` · `HelpersTest::testConvertToHijriValidDate`	سابق للبندين 9/10 (مطابق قبل/بعد)	الأول للاختبار الأول:على الأرجح بقاء فرض `Auth::is('Admin')`؛ يُحدَّث ليطابق `Auth::can('users.*')`
4	**تعليقات `Employee.php` تالفة الترميز** (نص مُتسرِّب)	تشويش على القراءة فقط، ولا يمسّ التنفيذ	تنظيف في بند موثقيات لاحق (لا تدخل في بند وظيف)
5	**أربعة أسطر فيها محارف تالفة (U+FFFD)** في `CHANGELOG.md` (مدخل CD-003 بتاريخ 2026-09-15)	سابق لكل تغييراتي (تحقّقتُ من النسخة المُودَعة في Git)	إصلاح بترميز النص الأصلي لا بالتخمين

---

7. فجوات موثّقة ومُحوَّلة للمراجعة (لا تُنفَّذ الآن)

1. **فشل تغيير الدور بلا Audit (البند 9):** بنص البند 9 لم يُطلب Audit عند الفشل و`Audit.php` خارج نطاقه. فالمحاولة الفاشلة لتغيير دور مستخدم **غير قابلة للتتبّع** في `audit_logs` — عكس البند 10 الذي أضاف ثلاثة أحداث `*_USER_CREATE_BLOCKED`. **مرشّح للمراجعة في CD-007+** (أو بند لاحق). 2. **واجهة `admin/roles/` معلّقة** مرشّحة **للبند 11** (لا علاقة لها بالبندين 9/10). 3. **OOS-8** (ومعه...) مؤجَّل إلى **البند 12-b**، و**OOS-1** إلى **CD-007**، بحسب خطة الاستشار. 4. **تنظيف بقايا الاختبار** (26 حسابًا) مرتبط بقرار المستشار Q3 ويُنفَّذ في **البند 11**.

---

8. التوصيات والمخاطر

• **المخاطر المغلقة:** تلف بيانات عند استبدال الدور (البند 9) · رسائل مضلِّلة + محاولات غير قابلة

للتتبّع عند إنشاء المستخدم (البند 10) · حارس اسم‌لا‌صلاحية وصفحات غير محمية (البند 7). ـ **قبل البند 11:** أ) حسم الفجوة (1) في §7 مع المستشار؛ ب) إصلاح `RouterTest` أو تحويله إلى ملف منفصل حتى لا يُسقط المجموعة الكاملة؛ ج) تقرير عن تضخيم `AuthTest` (§6–#1). ـ **الشرط:** لا يُبدأ أي بند بعد 10 قبل اعتماد هذا التقرير من المستشار.